



[.\(https://hackmd.io/@nbv9_cSa/](https://hackmd.io/@nbv9_cSa/) /  Deauth 與 Evil Twin ...







Deauth 與 Evil Twin 整合攻擊鏈測試流程

計畫：車聯網資安測試技術研究（ARTC 委託 / 經濟部產業技術司指導）

對象：T-BOX Client/Station 模式（OTA 更新 / 連接公共熱點）

環境：RF 隔離環境（屏蔽箱 / 電波暗室）

一、攻擊鏈關係說明

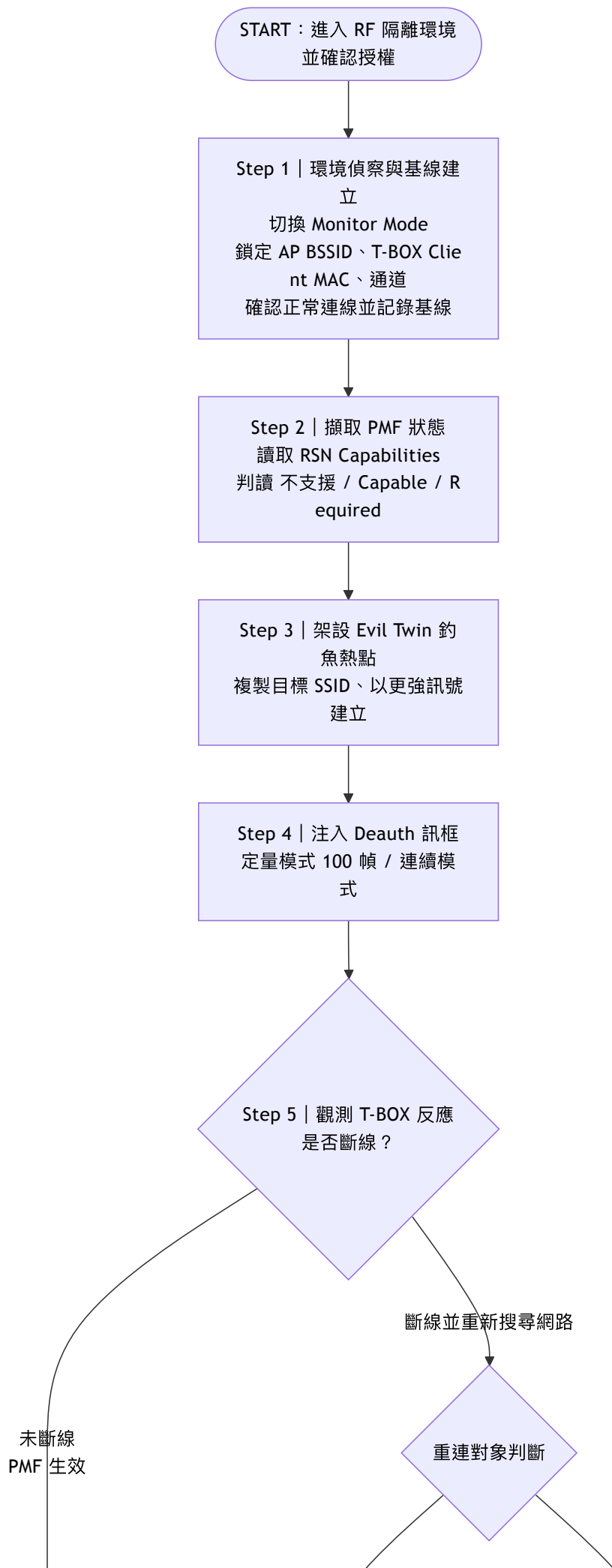
Deauth（解除認證）與 Evil Twin（釣魚熱點）為一組具前後因果關係的攻擊鏈：

Deauth 作為「強制斷線」的前置手段，**Evil Twin** 作為「誘導重連」的導向目標。攻擊者先架設一個複製目標 SSID、訊號更強的釣魚熱點，再對已連線的 T-BOX 注入 Deauth 訊框迫使其斷線；T-BOX 於重新搜尋網路時，若僅依 SSID 名稱自動連線，便會誤連至攻擊者控制的 Evil Twin，進而遭受中間人攻擊（MITM）、憑證竊取或惡意 OTA 導向。



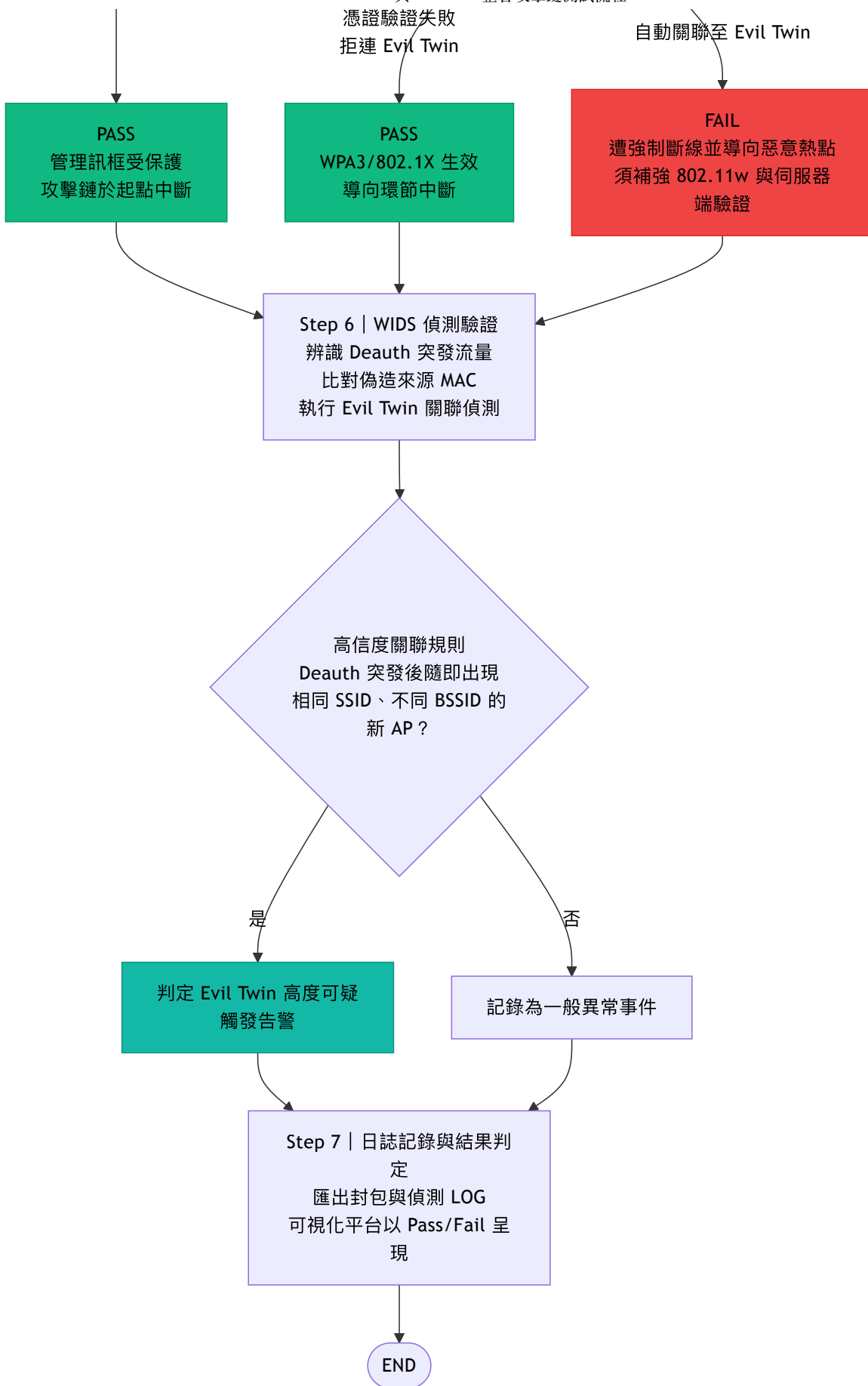
二、測試流程圖





憑證驗證失敗
拒連 Evil Twin

自動關聯至 Evil Twin





三、各步驟說明

Step 1 | 環境偵察與基線建立

切換網卡至 Monitor Mode，掃描並鎖定目標 AP 的 BSSID、T-BOX 端 Client MAC 及運作通道；確認 T-BOX 已完成四向握手、處於正常連線狀態，記錄訊號強度與連線參數，作為後續判斷基線。

Step 2 | 擷取 PMF 狀態

從 AP 的 Beacon / Association Response 擷取 RSN Capabilities 欄位，判讀 PMF 為「不支援 / Capable（可選） / Required（強制）」，作為預期結果之依據。

Step 3 | 架設 Evil Twin 釣魚熱點

複製目標 SSID，以更強訊號建立釣魚熱點；視測試需要可設定為開放式或偽造加密，用以驗證 T-BOX 端是否進行伺服器端憑證驗證。

Step 4 | 注入 Deauth 訊框

對目標 Client 發送解除認證訊框，分兩種模式執行：

- **定量模式**：發送固定數量（如 100 幀），用於精確重現與比對
- **連續模式**：持續注入，模擬真實 DoS 壓力情境

Step 5 | 觀測 T-BOX 反應與重連行為

監控 T-BOX 是否斷線，以及斷線後的重連對象——是否因 PMF 生效而未斷線，或斷線後自動關聯至 Evil Twin、抑或因憑證驗證失敗而拒絕連線。

Step 6 | WIDS 偵測驗證

確認偵測模組能否在滑動時間窗內辨識 Deauth 突發流量，並比對來源 MAC 是否為「未完成握手卻發出 Deauth」之偽造來源；同時執行 Evil Twin 關聯偵測。

Step 7 | 日誌記錄與結果判定

匯出全程封包與偵測 LOG，於可視化平台以 Pass/Fail 標示，並保留詳細技術細節供稽核。



四、判定準則

結果	條件	資安意義
PASS	PMF (802.11w) 阻擋 Deauth 使 T-BOX 未斷線； 或雖斷線但因 WPA3 / 802.1X 憑證驗證失敗而拒連 Evil Twin	攻擊鏈於起點或導向環節即被中斷
FAIL	T-BOX 遭成功斷線並自動關聯至 Evil Twin	存在被強制斷線並導向惡意伺服器之風險 須補強 802.11w 與伺服器端驗證
WIDS PASS	偵測模組成功告警並匯出日誌	具備主動偵測與稽核能量

五、三道防線對應

防線	機制	作用環節
第一道	PMF (802.11w)	攻擊鏈起點阻擋 Deauth，使 T-BOX 根本不被斷線
第二道	WPA3 / 802.1X 伺服器端驗證	Evil Twin 無法提供合法憑證而遭拒 (最主要之防禦)
第三道	Client 端組態	避免僅憑 SSID 名稱自動加入未知網路

六、WIDS 高信度關聯規則

建立核心偵測規則：偵測到 **Deauth** 突發流量後隨即出現「相同 **SSID**、不同 **BSSID**」的新 **AP**，即判定為 Evil Twin 高度可疑特徵。此關聯訊號遠強於單獨偵測 Deauth 或 Rogue AP，並能於日誌中清楚呈現兩者的因果關聯，作為技術報告之佐證素材。